Phase 16: Security Hardening & Final Verification Audit

Course Code: 20CYS401 | **Project**: Online Book Review and Recommendation Platform

16.1 Security Hardening Measures Applied

Control ID	Hardening Category	Implementation Details	Verification
CTRL-01	Authentication & Sessions	Bcrypt with 12 rounds; HttpOnly, SameSite=Lax session cookies; session invalidation on logout	`tests/test_unit_auth.py`, `tests/test_integration_auth.py`
CTRL-02	Object-Level Authorization	Centralized `is_owned_by` verification in `ReviewService` and `ReadingListService`	`tests/test_authorization.py`, IDOR demo on branch `demo/idor-before`
CTRL-03	XSS Prevention	Jinja2 contextual autoescaping; HTML and null-byte input stripping	`tests/test_fuzzing.py::test_fuzz_xss_payloads_in_review`
CTRL-04	Input Validation	Strict ratings boundary checks (1–5 integer only); username and email validation	`tests/test_unit_validation.py`
CTRL-05	SQL Injection Defense	100% SQLAlchemy ORM parameterized queries; zero string-concatenated SQL queries	`tests/test_unit_search.py::test_search_sql_injection_metacharacters`
CTRL-06	Role-Based Access Control	`@admin_required` server-side decorator guarding `/admin/*` routes	`tests/test_authorization.py::test_normal_user_denied_admin_routes`
CTRL-07	Error Handling	Custom 400, 403, 404, 500 error templates avoiding stack trace leakage	`app/templates/errors/`
CTRL-08	Audit Logging	Tamper-evident `AuditLog` table with sensitive field scrubbing	`app/core/audit.py`, `/admin/moderation` log viewer
CTRL-09	HTTP Security Headers	CSP, X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Referrer-Policy	`app/__init__.py` after_request middleware
CTRL-10	Container Hardening	Multi-stage build, dedicated non-root user (UID 10001), drop capabilities ALL	`docker/Dockerfile`, `k8s/deployment.yaml`

16.2 Security Scan & Test Summary

- **Pytest Suite**: 23 tests executed, 23 passed, 0 failed.

- **Bandit SAST Scan**: 1032 lines scanned; 0 High, 0 Medium, 1 Low (hardcoded secret in test configuration `TestConfig`, documented as local test-only mock).
- **Secret Scan**: Clean; all sensitive credentials restricted to local `.env.example` templates and test fixtures.
- **IDOR Verification**: Demonstrated exploitable on `demo/idor-before` branch (`evidence/phase-12/idor_vulnerable_proof.txt`) and proven secured on `main` branch (`evidence/phase-12/idor_fix_verification.txt`).